Patient Data Handling and Consent Standard

MERIDIAN HEALTH PARTNERS
OPERATIONS POLICY MANUAL
STANDARD: CLINICAL AND ADMINISTRATIVE DATA HANDLING
DOCUMENT ID: MHP-OP-2024-DH-014
EFFECTIVE DATE: OCTOBER 1, 2024
APPLIES TO: ALL 14 CLINICAL SITES AND ADMINISTRATIVE HEADQUARTERS

1. PURPOSE AND JURISDICTION

1.1 This standard establishes mandatory operational protocols for the collection, access, retention, disclosure, and breach response concerning Protected Health Information (PHI) and Personal Data (PD) across all Meridian Health Partners (MHP) facilities.

1.2 MHP operates under dual regulatory frameworks: the Health Insurance Portability and Accountability Act (HIPAA) and the Digital Personal Data Protection Act 2023 (DPDP Act). Where statutory thresholds differ, staff shall apply the standard that provides the highest degree of data protection.

1.3 Compliance with this document is mandatory for all full-time, part-time, contractor, and locum tenens personnel. Violations are subject to disciplinary action up to and including immediate termination and credential revocation.

2. CONSENT CAPTURE PROTOCOL

2.1 Mandatory Collection: No personal or clinical data shall be collected without explicit, affirmative, and documented consent obtained prior to or at the time of patient intake, except in medical emergencies where consent is physically or cognitively impossible to capture.

2.2 Format and Language: Consent forms must be presented in the patient's primary language, utilizing the MHP-approved electronic health record (EHR) module (MedAccess v8.4). Verbal consent is strictly prohibited for non-emergency clinical intakes.

2.3 Granularity Requirements: Consent must distinguish between:

(a) Treatment, payment, and healthcare operations (TPHO);

(b) Internal quality improvement and audit;

(c) Third-party medical research participation.

2.4 Revocation Mechanism: Patients retain the right to withdraw consent at any time through the MHP Patient Portal or by submitting Form MHP-DC-02 to the Site Privacy Coordinator. Revocation shall take effect within twenty-four (24) hours of receipt, save for data already processed under lawful prior obligations.

3. MINIMUM NECESSARY ACCESS

3.1 Role-Based Access Control (RBAC): Access to patient records within MedAccess is restricted strictly on a need-to-know basis mapped to specific job descriptions maintained by the Human Resources Department.
3.2 Access Tiers:
(a) Tier 1 (Attending Clinicians & Nurses): Full read/write access to clinical notes, diagnostic results, and medication history for actively assigned patients.
(b) Tier 2 (Administrative Front Desk): Access limited to demographic data, insurance verification, and appointment scheduling fields. Clinical notes are masked.
(c) Tier 3 (Billing & Revenue Cycle): Access restricted to billing codes, dates of service, and relevant diagnosis codes. Complete clinical narratives are redacted.
3.3 Break-the-Glass Protocol: Emergency access override ("break-the-glass") is logged automatically. Any employee utilizing this override must submit a written justification to the Compliance Officer (Dr. Aris Thorne) within twelve (12) hours of the event. Unjustified overrides trigger a mandatory security audit.

4. DATA RETENTION PERIODS BY RECORD TYPE

4.1 All physical and electronic records must be retained in accordance with the following schedule, calculated from the date of the last encounter or the patient's eighteenth (18th) birthday, whichever is later:

Record Type	Retention Period	Disposition Method
Adult Clinical & Health Records	10 years	Secure cryptographic erasure / Cross-cut shredding
Pediatric Clinical Records	Until patient turns 28 years of age	Secure cryptographic erasure / Cross-cut shredding
Diagnostic Imaging & Pathology Slides	10 years	Digital purging from PACS / Incineration of physical blocks
Financial, Billing, and Claim Records	7 years	Automated batch deletion from ERP database
Patient Consent & Authorization Forms	10 years	Electronic archive with immutable timestamp
CCTV Footage at Facility Access Points	90 days	Automatic overwriting in local NVR storage

4.2 Premature destruction of records is prohibited. Hold notices issued by the Legal Department override all scheduled destruction timelines.

5. PATIENT DATA-ACCESS REQUEST (DAR) PROCESS

5.1 Submission: Patients may submit a Data-Access Request via the MHP Patient Portal, via certified mail using Form MHP-DAR-01, or in person at any of the 14 clinic sites.
5.2 Verification: Staff must verify the identity of the requester using a government-issued photo ID before releasing records.
5.3 Response Deadline: MHP shall fulfill all valid data-access requests within fifteen (15) calendar days from the date of formal receipt. If a complex request requires an extension, the Data Protection Officer (DPO) may grant a single extension not to exceed ten (10) additional calendar days, provided written notice of delay and reason is delivered to the patient prior to the expiration of the initial 15-day window.
5.4 Fees: The first electronic copy of records requested per calendar year shall be provided at no cost. Subsequent requests or physical paper copies exceeding 50 pages incur a standard administrative fee of $0.25 per page plus actual postage costs.

6. BREACH NOTIFICATION TIMELINE

6.1 Internal Escalation: Any employee who suspects or detects an unauthorized acquisition, access, use, or disclosure of unencrypted PHI/PD must report the incident to the Information Security Officer (ISO) within two (2) hours of discovery.
6.2 Risk Assessment: The Incident Response Team (chaired by ISO Marcus Vance) shall complete a forensic risk assessment within twenty-four (24) hours of internal notification to determine the probability of data compromise.
6.3 Regulatory Notification (DPDP Act / HIPAA):
(a) If the breach impacts data governed primarily under HIPAA involving 500 or more individuals, MHP shall notify the Secretary of Health and Human Services and prominent media outlets without unreasonable delay and in no case later than sixty (60) calendar days from discovery.
(b) For breaches invoking the DPDP Act or involving high-risk personal data leakage, MHP shall notify the Data Protection Board of India and affected data principals within seventy-two (72) hours of establishing the breach.
6.4 Individual Notice: Affected patients shall be notified via written notice sent to their last known primary address and secure email within thirty (30) calendar days of breach confirmation, detailing the categories of data exposed, mitigation steps taken by MHP, and contact details for credit monitoring services provided at MHP’s expense.

DOCUMENT GOVERNANCE
Owner: Office of the Chief Compliance Officer
Review Cycle: Annual
Next Review: October 1, 2025
Approved By: Dr. Eleanor Vance, Chief Executive Officer, Meridian Health Partners